

Monitoring dan Evaluasi :  
Pertemuan 7

# IPB Food Hub & UMKM Management System

Kelompok Kelompok 9  
KOM1315 Semester Genap 2025/2026

Revandra Athaya Rizkika (G6401231125)  
Hanif Febrian (G6401231070)  
M. Rafi Pangestu (G6401231058)  
Surya Dharma Adhi (G6401231133)





## EKOSISTEM IPB FOOD & UMKM HUB

Platform digital untuk memfasilitasi transaksi makanan dan produk UMKM antara mahasiswa IPB dan pelaku usaha lokal.

### Masalah Keamanan yang Ingin Diselesaikan:



#### Pencurian Data Sensitif

Data pribadi pelaku usaha (NIK, nomor rekening, nomor e-wallet) dan data kontak mahasiswa (nomor telepon) disimpan secara mentah (plaintext) sehingga rentan dibocorkan oleh penyerang luar maupun pihak internal (insider threat).



#### Penyangkalan Transaksi (Repudiation)

Mahasiswa/UMKM dapat menyangkal terjadinya pemesanan atau penyelesaian transaksi makanan karena tidak adanya bukti transaksi yang sah secara kriptografis.



#### Pembobolan Sesi & Akun

Penggunaan algoritma hashing yang lemah atau tidak adanya pembatasan otorisasi peran (Role-Based Access Control).



#### Pelanggaran Hukum

Kebocoran data massal (Data Breach) yang melanggar regulasi perlindungan data pribadi (UU PDP).



#### Ancaman Fraud

Manipulasi status transaksi atau penipuan (Fraud) transaksi pemesanan makanan.



#### Dampak Reputasi

Hilangnya kepercayaan pengguna terhadap integritas platform.

AKTOR SISTEM



Mahasiswa (Pembeli)

Mencari makanan, melakukan pemesanan, melihat status pesanan, dan mengelola profil pribadi.



Pelaku UMKM (Penjual)

Mengelola produk/menu makanan, memproses pesanan, serta menerima pembayaran (menyimpan data rekening/e-wallet).



Admin (Pengelola)

Mengawasi aktivitas sistem, memantau audit log, dan mengelola status keaktifan user.

Fitur Utama

| Fitur Utama                                | Penjelasan Teknis                                                                      |
|--------------------------------------------|----------------------------------------------------------------------------------------|
| Secure Authentication & Session Management | Autentikasi berbasis JWT dengan penyimpanan password ber-salt Bcrypt.                  |
| Transparent Column Encryption              | Enkripsi transparan pada kolom sensitif database (AES-256-GCM).                        |
| Digital Signature Pesanan                  | Penandatanganan transaksi secara digital ketika status pesanan diubah menjadi selesai. |
| Protokol AAA dengan Audit Trail            | Pencatatan log aktivitas secara terstruktur dalam format JSON-lines.                   |

Arsitektur Singkat

| Komponen Asal                 | Protokol / Mekanisme              | Komponen Tujuan                           |
|-------------------------------|-----------------------------------|-------------------------------------------|
| Client (Browser / CLI Client) | HTTPS / TLS                       | API (FastAPI Backend Gateway)             |
| API (FastAPI Backend Gateway) | SQLAlchemy ORM with TypeDecorator | DB (SQLite / PostgreSQL Database)         |
| API (FastAPI Backend Gateway) | JSON-line File Appender           | Log (logs/aaa_accounting.log)             |
| API (FastAPI Backend Gateway) | RSA Keys                          | Keys (keys/private.pem & keys/public.pem) |

| Aset yang Dilindungi                                                                                |
|-----------------------------------------------------------------------------------------------------|
| Kredensial Pengguna: Password (dihash dengan Bcrypt).                                               |
| Data Pribadi Sensitif: NIK, Nomor Rekening, Nomor E-Wallet, Nomor Telepon (dienkripsi AES-256-GCM). |
| Integritas Transaksi: Data pesanan, total harga, status pesanan (diproteksi Tanda Tangan Digital).  |
| Log Sistem: Jejak audit log (AAA) untuk kepatuhan non-repudiation.                                  |

| Ancaman Utama & Risiko yang Diidentifikasi |                                                                                            |                                                |                                                                                           |
|--------------------------------------------|--------------------------------------------------------------------------------------------|------------------------------------------------|-------------------------------------------------------------------------------------------|
| Ancaman (STRIDE)                           | Skenario Ancaman                                                                           | Risiko & Dampak                                | Mitigasi                                                                                  |
| Spoofting                                  | Penyerang menyamar sebagai Mahasiswa atau UMKM menggunakan session token palsu.            | Akses akun ilegal, fraud pesanan.              | Implementasi JWT Token dengan kunci enkripsi kuat.                                        |
| Tampering                                  | Penyerang mengubah data sensitif NIK atau memodifikasi harga pesanan langsung di database. | Kerugian finansial, manipulasi data transaksi. | Autentikasi AES-256-GCM (mendeteksi tampering cipher) dan Digital Signature pada pesanan. |
| Repudiation                                | UMKM menyangkal telah menyelesaikan pesanan atau menerima uang.                            | Konflik transaksi, ketidakpercayaan sistem.    | Penandatanganan payload transaksi menggunakan RSA-PSS.                                    |
| Information Disclosure                     | Kebocoran data NIK dan rekening bank milik mitra UMKM.                                     | Pelanggaran privasi (UU PDP), reputasi buruk.  | Enkripsi kolom database menggunakan kunci AES-256-GCM.                                    |
| Elevation of Privilege                     | User Mahasiswa memanggil API Admin untuk mengaktifkan/menonaktifkan akun.                  | Kerusakan konfigurasi sistem.                  | Role-Based Access Control (RBAC) di tingkat router API.                                   |



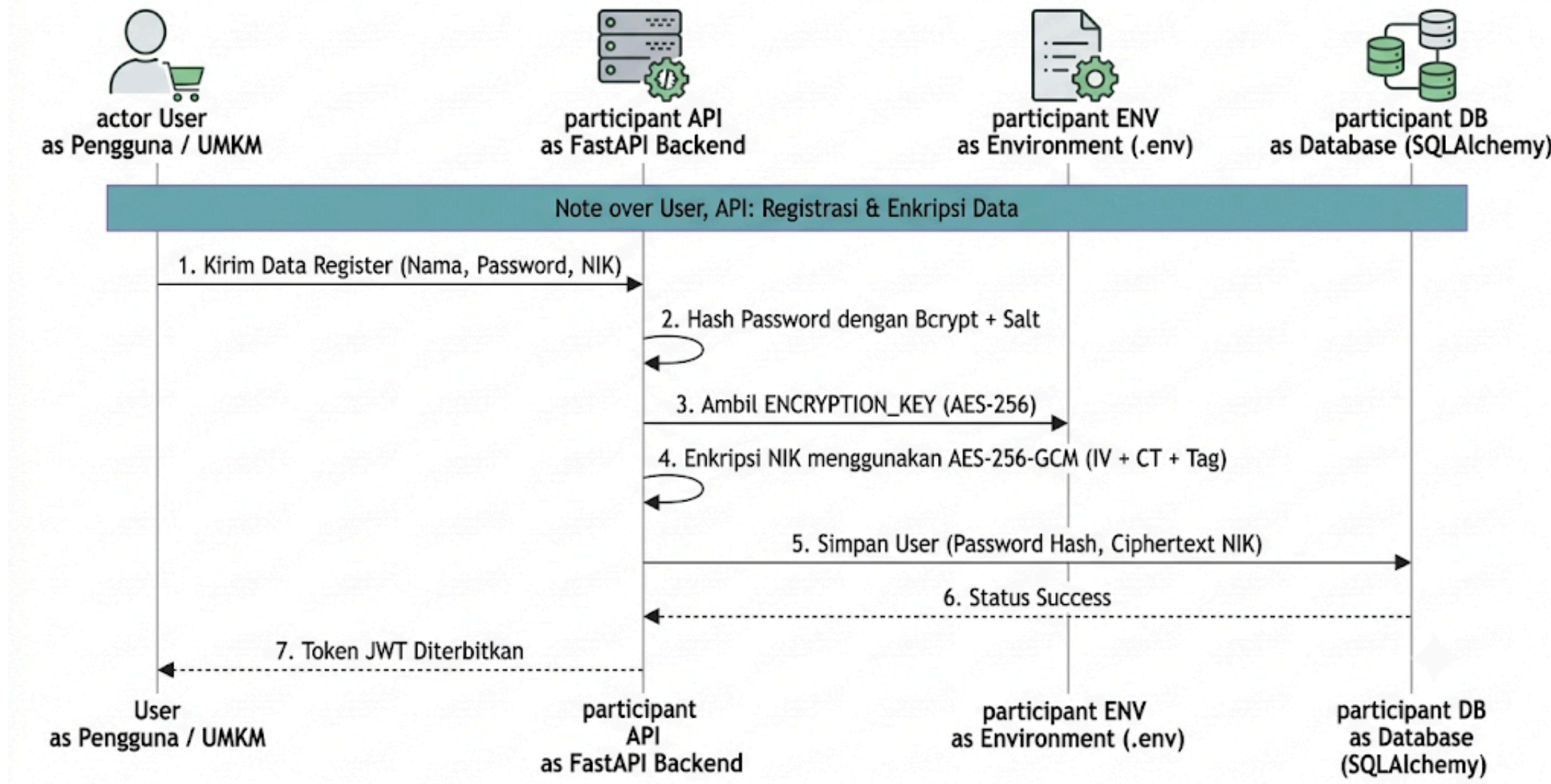
Untuk menangani ancaman di atas, sistem wajib memenuhi aspek keamanan berikut:



| Aspek Keamanan                | Spesifikasi & Skema                                                                                                                                                                                                            |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Confidentiality (Kerahasiaan) | <b>Data sensitif</b> seperti NIK, nomor rekening, dan nomor telepon <b>tidak boleh</b> tersimpan dalam bentuk <b>plaintext</b> .<br>Diimplementasikan menggunakan AES-256-GCM pada database.                                   |
| Integrity (Integritas)        | <b>Data transaksi pesanan</b> dilindungi dari perubahan yang <b>tidak sah</b> menggunakan skema tanda tangan digital RSA-PSS + SHA-256.                                                                                        |
| Availability (Ketersediaan)   | <b>Sistem</b> dibangun menggunakan <b>FastAPI</b> yang <b>asinkron</b> , memiliki <b>validasi</b> skema input (Pydantic), serta penanganan <b>exception</b> yang <b>baik</b> agar terhindar dari crash akibat input berbahaya. |
| Authentication (Autentikasi)  | <b>Pembuktian</b> identitas user melalui <b>hashing password</b> dengan <b>Bcrypt</b> (cost factor 12) dan <b>session</b> berbasis JSON Web Token (JWT).                                                                       |
| Authentication (Autentikasi)  | Pembatasan <b>hak akses</b> endpoint API menggunakan <b>Role-Based Access Control (RBAC)</b> melalui <b>middleware decorator require_role</b> .                                                                                |
| Authentication (Autentikasi)  | <b>Perekaman</b> log aktivitas sistem secara <b>lengkap</b> (siapa, melakukan apa, kapan, dan dari IP mana) melalui <b>AAA Accounting Log</b> dalam format JSON-lines.                                                         |

Desain pengamanan data dibagi menjadi tiga skenario utama:

DIAGRAM ALUR DATA & KUNCI KEAMANAN



| Kategori Keamanan                | Mekanisme / Protokol                                                                                     | Detail Implementasi & Proteksi                                                                                                                                                                                   |
|----------------------------------|----------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data at Rest (Penyimpanan)       | <ul style="list-style-type: none"><li>Bcrypt</li><li>AES-256 (TypeDecorator)</li></ul>                   | <ul style="list-style-type: none"><li>Password di-hash satu arah secara lambat.</li><li>Kolom sensitif otomatis di-enkripsi saat INSERT/UPDATE dan di-dekripsi saat SELECT.</li></ul>                            |
| Data in Transit (Transmisi)      | <ul style="list-style-type: none"><li>HTTPS / TLS 1.3</li></ul>                                          | <ul style="list-style-type: none"><li>Mengamankan komunikasi client-server dari sadapan Man-in-the-Middle (MitM).</li></ul>                                                                                      |
| Key Management (Manajemen Kunci) | <ul style="list-style-type: none"><li>Variabel Lingkungan (.env)</li><li>RSA Keypair (./keys/)</li></ul> | <ul style="list-style-type: none"><li>Kunci AES simetris disimpan di .env dan masuk .gitignore.</li><li>Kunci privat &amp; publik RSA untuk Digital Signature disimpan lokal untuk proteksi transaksi.</li></ul> |



## Cara Kerja Autentikasi

### Registrasi



### Login



### Otorisasi Sesi



## Role-Based Access Control (RBAC)

Sistem menerapkan pembatasan akses di tingkat endpoint menggunakan factory function `require_role(["role"])`.

- Mahasiswa: Hanya dapat mengakses data pribadi mereka sendiri dan melakukan transaksi pemesanan.
- UMKM: Dapat mengakses data internal penjualan, mengelola produk makanan, serta menandatangani pesanan selesai.
- Admin: Memiliki akses ke log akuntansi (AAA), mengelola status keaktifan user, dan konfigurasi sistem global.





## Jejak Audit & Logging Aktivitas

Sistem mencatat setiap aktivitas penting ke dalam berkas logs/aaa\_accounting.log dalam format JSON-lines. Format ini sangat ramah untuk dikonsumsi oleh dasbor monitoring (seperti Grafana Loki atau ELK stack). Audit Log mencatat:

- ts: Timestamp (ISO 8601 UTC).
- user\_id: ID unik pengguna (atau email saat login).
- action: Jenis aksi (contoh: LOGIN\_SUCCESS, LOGIN\_FAILED, ACCESS\_GRANTED, ACCESS\_DENIED, USER\_REGISTER).
- details: Informasi tambahan mengenai aksi (contoh: alasan kegagalan login atau role pengguna).
- ip: Alamat IP asal klien (untuk deteksi anomali geografis).

| Dampak                             | Spesifikasi & Skema                                          | Solusi                                                                                                                                             | Spesifikasi & Skema                |
|------------------------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|
| AES (Advanced Encryption Standard) | AES-256-GCM (Galois/Counter Mode)                            | Mendukung Authenticated Encryption (AEAD). Menjamin kerahasiaan sekaligus integritas data (mendeteksi tampering di DB melalui Authentication Tag). | core/crypto.py                     |
| RSA (Rivest-Shamir-Adleman)        | RSA-2048 dengan padding PSS (Probabilistic Signature Scheme) | Standar modern untuk pembuatan tanda tangan digital asimetris yang aman dari serangan modifikasi tanda tangan.                                     | auth/digital_signature.py          |
| SHA-256                            | Secure Hash Algorithm 256-bit                                | Fungsi hash satu arah untuk membuat sidik digital (digest) pesan sebelum ditandatangani oleh RSA-PSS.                                              | Terintegrasi pada proses signature |
| Tanda Tangan Digital               | Kriptografi Asimetris (RSA + SHA-256)                        | Menjamin sifat non-repudiation (anti-penyangkalan) pada pesanan makanan yang telah dinyatakan selesai.                                             | Terintegrasi pada alur transaksi   |





## Ringkasan Hasil Pengujian — 13/13 Pass

| No | Fitur Keamanan                 | File Implementasi                                                                                                                                                                                                       | Status   |
|----|--------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| 1  | Password Hashing (4 Kasus)     | Berhasil memverifikasi password benar, menolak password salah, membuktikan keunikan hash per panggilan (salt acak), dan memastikan penggunaan algoritma bcrypt dengan cost factor 12.                                   | Selesai✓ |
| 2  | Symmetric Encryption (4 Kasus) | Berhasil menguji siklus enkripsi-dekripsi data sensitif (NIK), menangani data null, menghasilkan ciphertext unik untuk input yang sama (IV acak), serta mendeteksi tampering pada ciphertext (memicu error InvalidTag). | Selesai✓ |
| 3  | JWT Token (1 Kasus)            | Memastikan format token valid (3 segmen base64 dipisah titik).                                                                                                                                                          | Selesai✓ |
| 4  | Digital Signature (2 Kasus)    | Memverifikasi tanda tangan digital valid pada data asli dan menolak tanda tangan jika payload data telah dimodifikasi (tampering).                                                                                      | Selesai✓ |
| 5  | Authorization/RBAC (2 Kasus)   | Memastikan user ber-role Mahasiswa ditolak saat mengakses endpoint Admin (memicu error HTTP 403), dan mengizinkan akses jika user ber-role Admin.                                                                       | Selesai✓ |



| Parameter Kinerja          | Sebelum Keamanan        | Sesudah Keamanan                                                                                       | Analisis Dampak Keamanan                                                                                                                                                                                               |
|----------------------------|-------------------------|--------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Response Time (Login)      | ~15 ms                  | ~265 ms                                                                                                | Terjadi peningkatan waktu respons sekitar 250ms akibat beban komputasi CPU untuk Bcrypt Hashing (cost 12). Ini disengaja sebagai bentuk pertahanan dari serangan brute-force.                                          |
| Response Time (Query User) | ~3 ms                   | ~4.5 ms                                                                                                | Overhead dekripsi transparan AES-256-GCM sangat kecil (~1.5 ms), tidak mengganggu pengalaman pengguna.                                                                                                                 |
| Ukuran Penyimpanan Data    | NIK: 16 char (16 bytes) | NIK Cipher: 88 char (88 bytes)                                                                         | Enkripsi AES dan encoding base64 meningkatkan ukuran penyimpanan kolom sensitif sebesar kurang lebih 5 kali lipat. Namun, tidak memengaruhi kinerja DB secara umum karena volume data sensitif per baris sangat kecil. |
| Penggunaan CPU/RAM         | Rendah (< 5%)           | Sedikit peningkatan pada CPU (puncak ~20%) saat proses login/register karena proses matematika Bcrypt. | Beban CPU kembali normal setelah sesi terotentikasi terjalin (verifikasi JWT sangat ringan).                                                                                                                           |



| Kategori Evaluasi          | Poin-Poin dan Detail Penjelasan                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Pencapaian Tujuan       | <ul style="list-style-type: none"><li>Backend Tangguh: Membangun sistem backend API (FastAPI) yang terproteksi dengan protokol AAA.</li><li>Keamanan Data at Rest: Mengamankan data sensitif pengguna (NIK, Rekening) di database menggunakan enkripsi AES-256-GCM.</li><li>Non-Repudiation: Menghindari penyangkalan transaksi menggunakan tanda tangan digital RSA-PSS pada data pesanan yang diselesaikan.</li><li>Akuntabilitas: Menyediakan jejak audit log akuntabilitas yang terstruktur.</li></ul>       |
| 2. Keterbatasan Sistem     | <ul style="list-style-type: none"><li>Kunci Lokal: Kunci kriptografi dan file konfigurasi sensitif masih di folder lokal server, belum terintegrasi dengan pengelola kunci cloud terpusat.</li><li>Ketiadaan MFA: Belum ada mekanisme autentikasi dua faktor (Multi-Factor Authentication) untuk akun admin atau UMKM.</li><li>Fitur Bisnis Terbatas: API baru mengimplementasikan fitur autentikasi dan manajemen akun user.</li></ul>                                                                          |
| 3. Pengembangan Berikutnya | <ul style="list-style-type: none"><li>Integrasi HSM/Cloud KMS: Menyimpan kunci enkripsi dan kunci privat RSA menggunakan layanan KMS (seperti Google Cloud atau AWS KMS) demi keamanan dari administrator lokal.</li><li>Implementasi MFA: Menambahkan verifikasi TOTP (Time-based One-time Password) seperti Google Authenticator saat login.</li><li>Endpoint Transaksi: Membuat API router lengkap untuk pemesanan makanan, katalog menu, dan riwayat pesanan dengan tanda tangan digital otomatis.</li></ul> |



# Terimakasih

